FINANCIAL SERVICES ISAC

Threat Intelligence Sharing in the Financial Sector

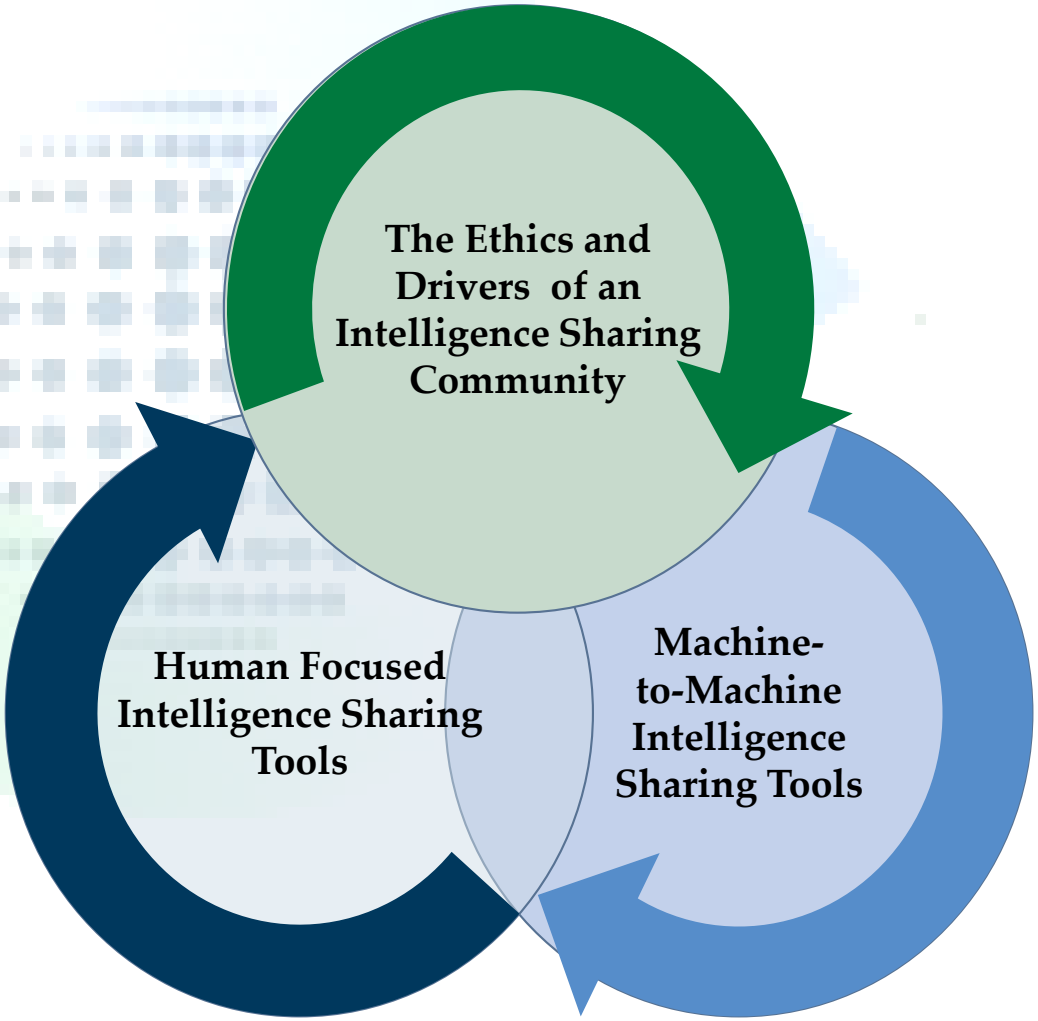
Ray Irving – rirving@fsisac.eu

Financial Services
Information Sharing & Analysis Center

Sharing Communities Commonly Include Three Elements

Before any real sharing can begin a lot has to happen:

- **There has to be clear reasons for competitors to come together**
- **There have to be ways and means of coming together**
- **There have to be guidelines, rules or norms to define how the community operates**



FINANCIAL SERVICES ISAC

Today's Threats to Banking and Finance

39% of firms report being cybercrime victims in the last 12 months

41% of firms believe they will experience cybercrime within 24 months

13M Identity Fraud Victims in 2013

28% of fraud related to account takeovers

>€22B Expected IT security spending by 2017

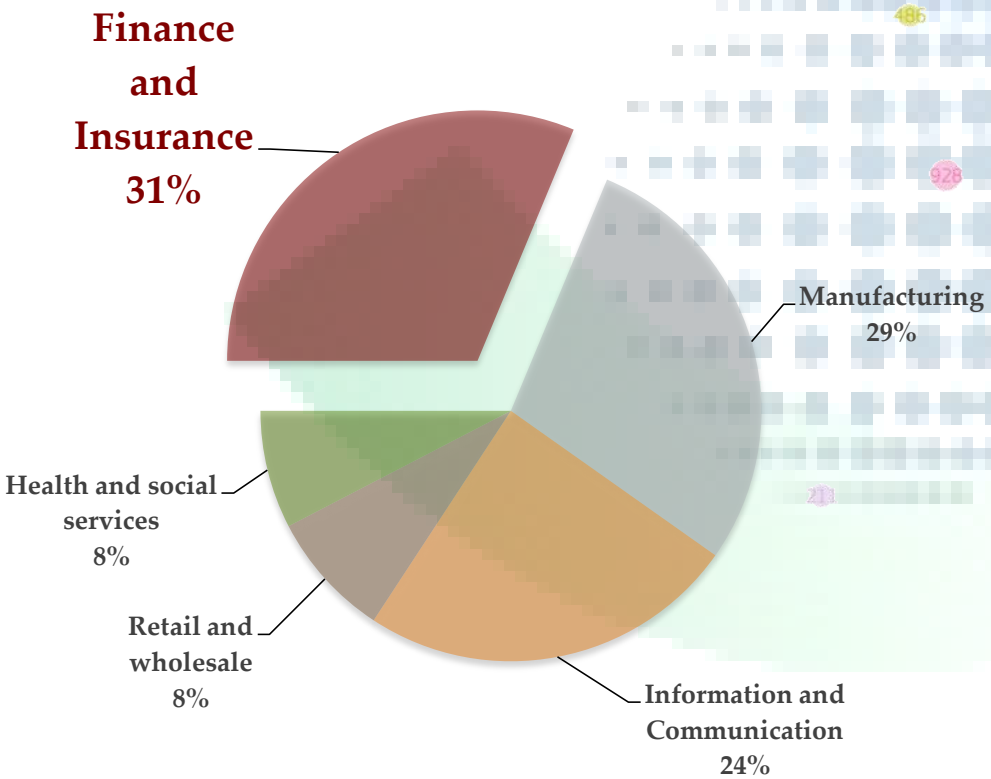
FINANCIAL SERVICES ISAC

1) http://www.pwc.com/economiccrime
2) https://www.javelinstrategy.com/news/1467/92/A-New-Identity-Fraud-Victim-Every-Two-Seconds-in-2013-According-to-Latest-Javelin-Strategy-Research-Study/d,pressRoomDetail
3) http://www.canalys.com/newsroom/it-security-spend-reach-301-billion-2017

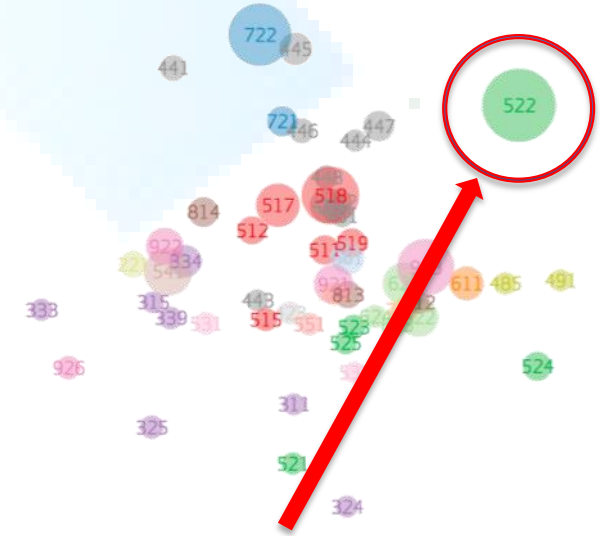
Target: Financial Sector

"Because That's Where The Money Is…" –Willie Sutton

Share of observed attacks by industry(2013)[1]



Uniqueness of breaches by industry (2014)[2]

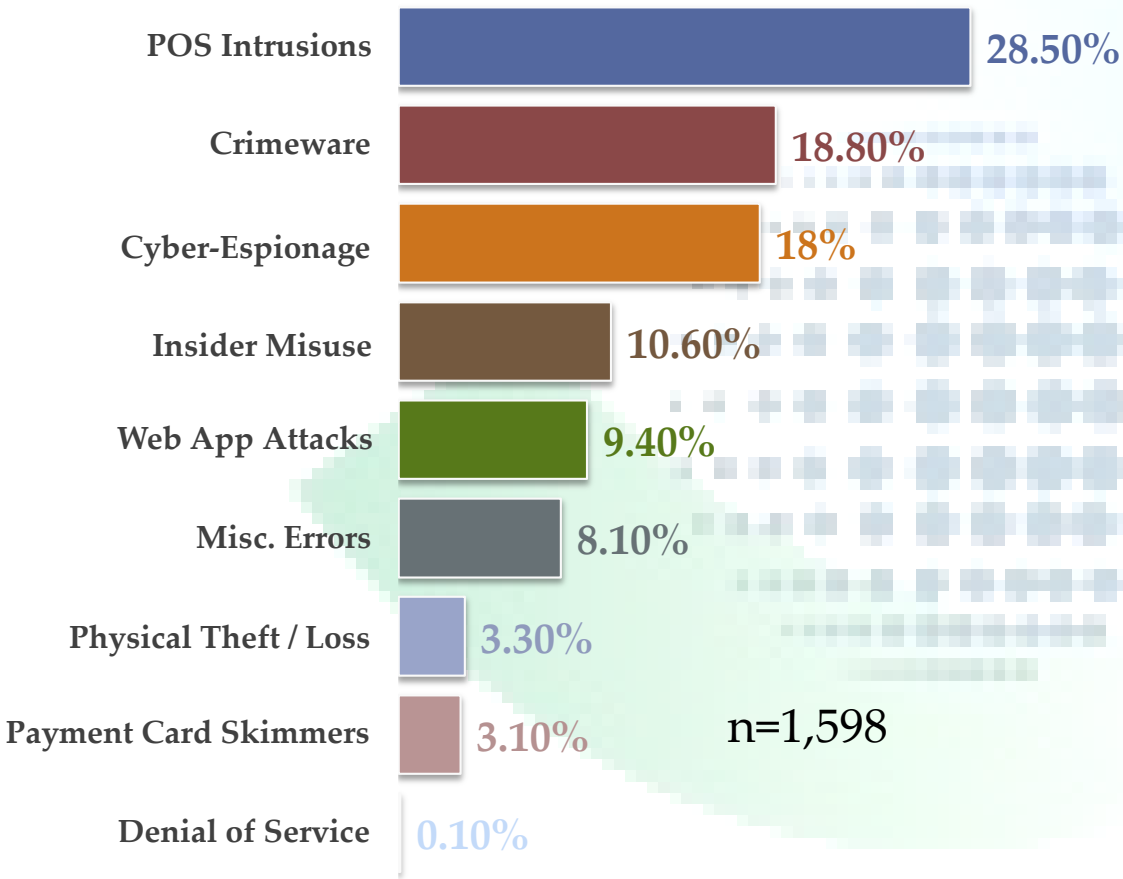


FINANCIAL SERVICES ISAC

Sources: [1]*IBM 2014 Cyber Security Intelligence Index*
[2]*Verizon 2015 DBIR*

Frequency of Incident Classification Patterns

(Percentage Across Confirmed Data Breaches 2014)



- **Top concerns**: POS intrusions, web app attacks, espionage, and card skimmers
- **Threat profiles vary by region** (e.g.: European EMV less vulnerable to skimming, different mobile usage patterns, etc.)
- **Mobile does not appear to be a top issue**– but depends on your risk exposure
- **Phishing** is on the rise. Did it ever stop?

FINANCIAL SERVICES ISAC

Source: Verizon, [2015 Data Breach Investigations Report]

The Need For Speed

Attackers Act 150x Faster Than Victims Respond

	Seconds	Minutes	Hours	Days	Weeks	Months
Initial Attack to Initial Compromise (Shorter Time Worse)	10%	75%	12%	2%	0%	1%
Initial Compromise to Data Exfiltration (Shorter Time Worse)	8%	38%	14%	25%	8%	8%
Initial Compromise to Discovery (Longer Time Worse)	0%	0%	2%	13%	29%	54%

Attackers have honed their skills to come at you rapidly

Defenders take a long time to feel the impact of an attack

FINANCIAL SERVICES ISAC

Threats Evolve

CryptoLocker (2013)

CryptoWall (2014)
- *Version 1.0*
- *Version 2.0*
- *Version 3.0*

TorrentLocker (2014)

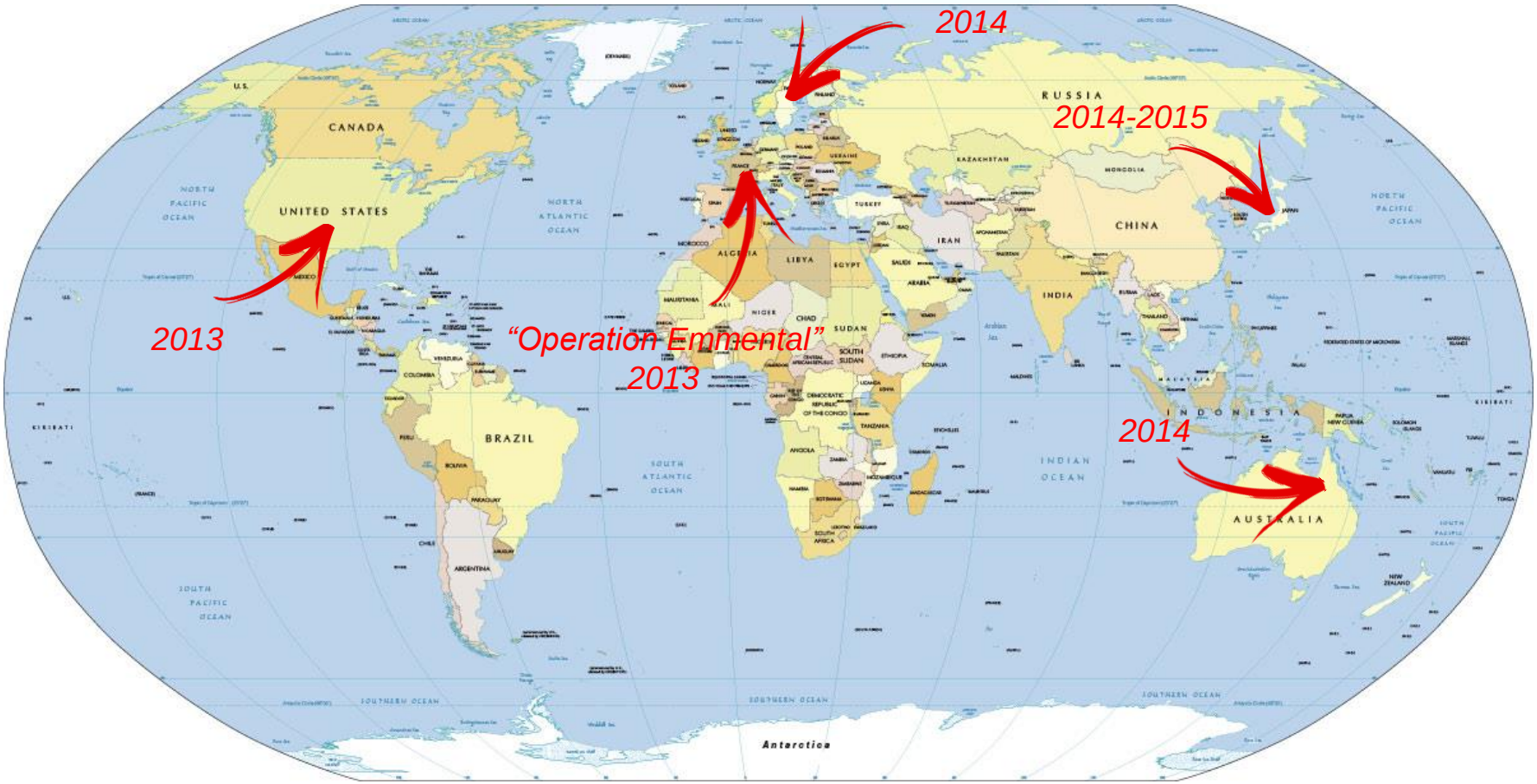
TeslaCrypt (2015)
- *Version 1.0*
- *Version 2.0*

CTB Locker (2015)

FINANCIAL SERVICES ISAC

Threats Spread

E.g. Retefe Banking Trojan



FINANCIAL SERVICES ISAC

Attacks Become International

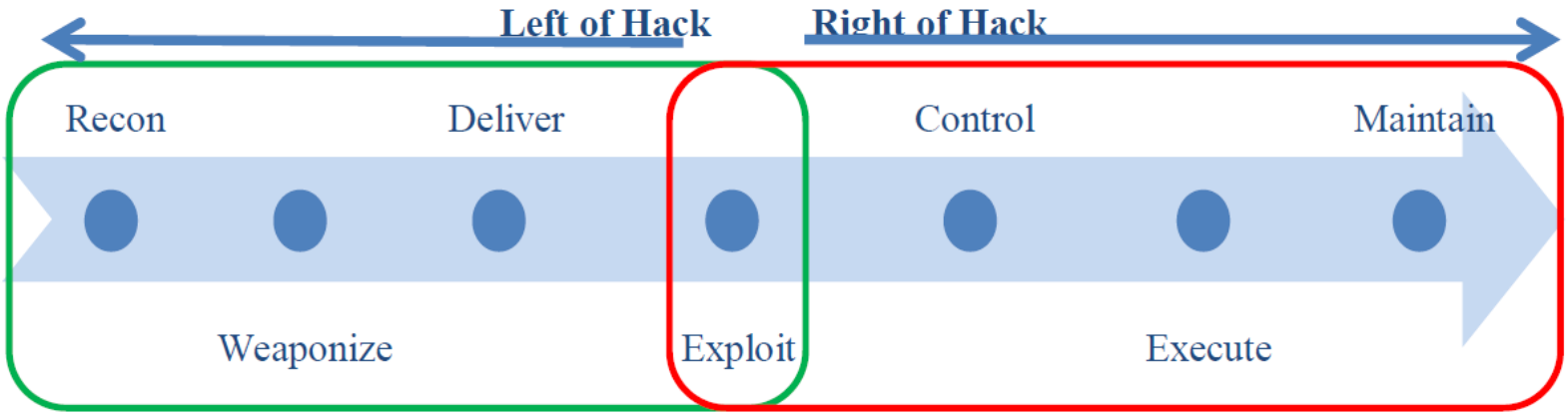
- Increasing sector- or region-specific threats and attacks
- Attacks spread across countries / regions
- Growing technological sophistication
- Ease of attacks

- Too much information
- Local / individual response
- Regulatory pressure

Cooperation Becomes Vital

FINANCIAL SERVICES ISAC

The Intel Sharing Business Case



Example Cyber Kill Chain

- Responding to incidents after the event is very costly.
- Proactive organisations need to move "left of the hack"
- It is not cost effective to do this with a purely compliance driven approach.
- This strategy requires **Cyber Threat Intelligence**.

FINANCIAL SERVICES ISAC

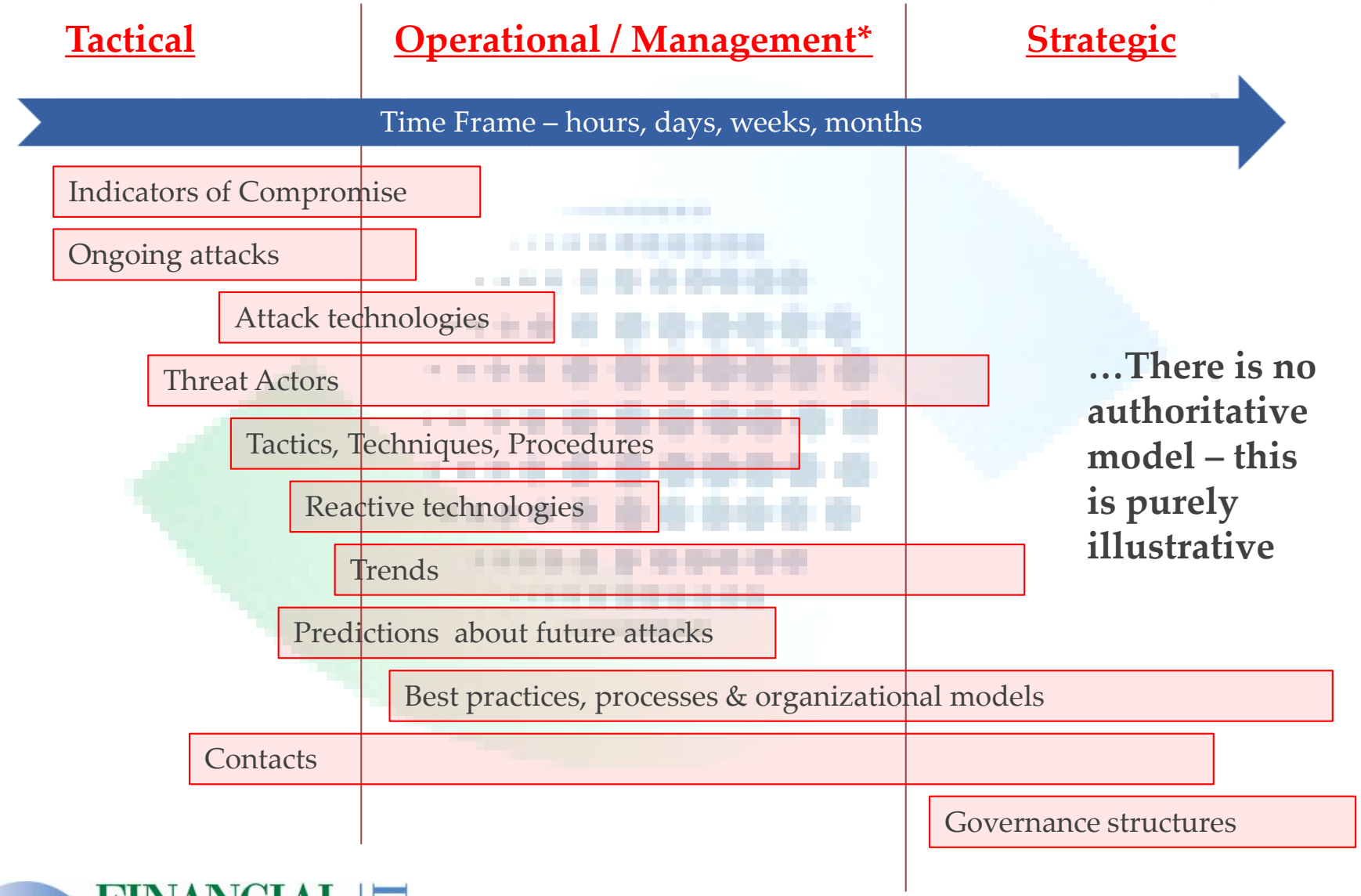
Source: Lockheed Martin [Intelligence-Driven Computer Network Defense]
Diagram: MITRE [Standardizing Cyber Threat Intelligence Information with STIX]

What is Threat Intelligence?

Tactics, Techniques, Procedures (TTP)

FINANCIAL SERVICES ISAC

Levels of Information Sharing



…There is no authoritative model – this is purely illustrative

FINANCIAL SERVICES ISAC

Challenges to Intel Sharing in Europe (1)

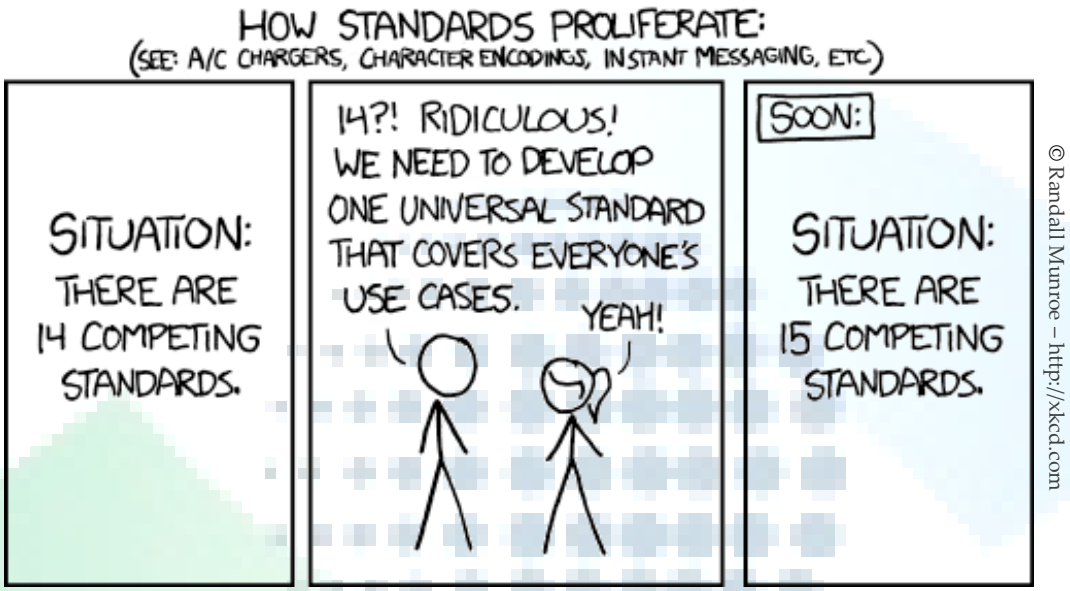
The Will is Usually There…

- Diverse, Evolving Regulatory Requirements
  - Large FIs tend to rely on regulatory „stick“ to budget appropriately
  - ➢ Insecurity about what's coming – NIS directive, IT-Sicherheitsgesetz...what does it mean for us?
- Legal Blocks, Real or Perceived
  - Perceived legal blocks (e.g. data protection laws) to information sharing
  - Wide range of laws and perceptions of confidential data -> and what does the legal department say?
  - ➢ What may I share? What can't I share? With whom? → Numerous efforts in progress to define this
- Best Practices & Maturity Gaps
  - Intelligence sharing is still new for many organizations
  - Lack of visibility of incident management processes / intel analysis and sharing within firms
  - „Risk transparency“ is often a dirty, dirty phrase
  - ➢ How do I best benefit? What should processes look like?

FINANCIAL SERVICES ISAC

Challenges to Intel Sharing in Europe (2)

Who Is Responsible For What?



- Many arise in isolation – nature abhors a vacuum
- Some national, regional, sector capabilities very mature – what about international?
- Frequently the result of cultural, language factors
- Relationships often highly personal, ad hoc → fragmented landscape
- Cross-sector communication?
- ➢ Lack of clarity about responsibilities, maturity, points of contact, etc.

We should probably do something about these…

FINANCIAL SERVICES ISAC

Challenges to Intel Sharing in Europe (3)

No, Seriously, It Is.

- Too Much Information
  - Many organizations flooded with unfiltered intel
  - Much global intel not regionally / locally relevant
  - ➢ Helping members develop analysis and filtering capability, creating targeted intel flows
- Law enforcement / regulators?
  - Few standards for interacting with police and financial regulators in case of a breach
  - „The police are a black hole“
  - ➢ How to ensure incidents / threats / breaches are processed pragmatically? The right people are involved?
- Other Intel Sources: Competition vs. Complement?
  - „But we already have a provider“ -> Good! Keep them! Multiple sources of information are not mutually exclusive
  - Participating in an intel scheme helps leverage existing security expenditure
  - ➢ Bringing threat intelligence into a global context – not just geographically, but industry-wide

FINANCIAL SERVICES ISAC

A Few Points About „Information Sharing“

Everybody talks about it, but what does it mean?

- Just talking about Information sharing **is not** information sharing
  - ✓ Put up or shut up!
- The more you contribute, the more you get out of it
  - ✓ Participation motivates others to also participate
  - ✓ Sharing leverages and multiplies the value of existing feeds, contacts, and resources
- There is no „wrong“ way to share information
  - ✓ Threat intel, best practices, op models, processes, it‘s all useful to somebody
  - ✓ It‘s not just about your threat intel teams – also legal, investigations, etc.
  - ✓ Guess what? **Everyone has similar problems and questions as you do.**
- Threat intel is NOT A COMPETITIVE ADVANTAGE
  - ✓ Focus on your core business. Collaboration strengthens everybody
- Trust is everything
  - ✓ Whether rule-based or knowing your counterparts from face-to-face meetings

→ Participate in an information sharing scheme
→ Make sure you‘re talking to other schemes

FINANCIAL SERVICES ISAC

Imagine A World Where...

5000+ Financial services firms around the world actively sharing real-time threat information

12M Threat indicators automatically analyzed, prioritized, turned into actionable intelligence

5500 Prioritized incident & threat alerts shared/year

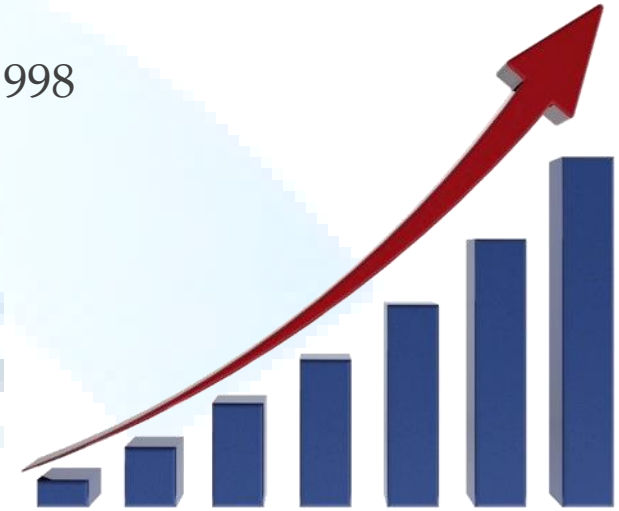
400 Key cyber intelligence email list posts / month

10x Reduction in time to respond to threat indicators via industry-created automation tools and feeds

FINANCIAL SERVICES ISAC

About FS-ISAC

MISSION: To Share Timely, Relevant, Actionable Digital and Physical Security Information & Analysis Specific to Financial Services



- A **not for profit** private sector initiative formed in 1998
- Created by financial services, for financial services
- Information sharing: both human and automated - to detect, prevent, respond to attacks & fraud
- Ca. 6,000 members on 6 continents
- Strong growth & traction globally in all major regions
- Regional / national staff: UK, continental Europe, US, Canada, Japan, Singapore; Security Operations Centers (SOC) in US, Poland

"The FS-ISAC is not a service provider, it's a community…Like neighborhood watch for electronic and physical hazards."

FINANCIAL SERVICES ISAC

FS-ISAC: Operational Intelligence Shared

Threats, Vulnerabilities, Incidents

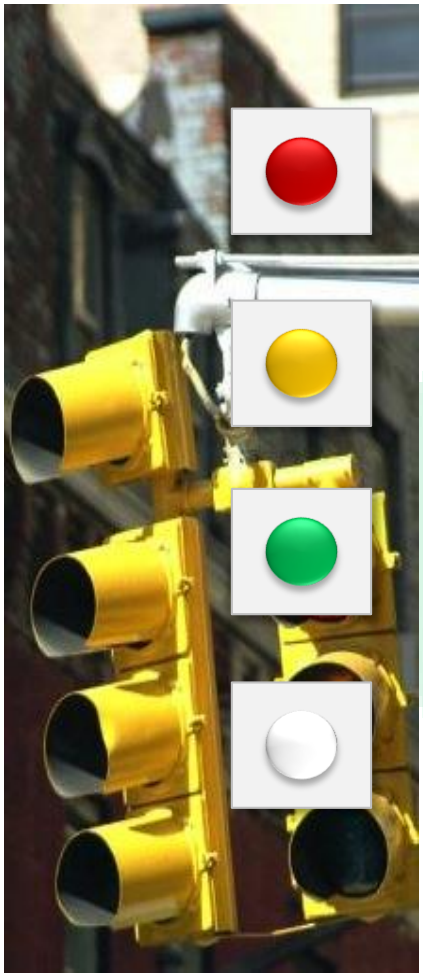
- Malicious Sites
- Threat Actors, Objectives
- Threat Indicators
- TTPs, Observables
- Courses of Action
- Exploit Targets
- Denial of Service / DDoS
- Malicious Emails: Phishing/ Spearphishing
- Software Vulnerabilities
- Malicious Software (Malware)
- Analysis and risk mitigation
- Incident response techniques
- Attack trends & predictions

Via…

- ✓ Cyberintel mailing lists – US & EU, APAC, ES (Spanish-speaking)
  - 1500+ subscribers
  - 179 companies
  - 400+ posts/month
- ✓ Portal – with anonymous member submissions from 37 countries
- ✓ Biweekly threat calls – US, Europe, APAC
- ✓ Regular workshops, member meetings & briefings
- ✓ Threat Intelligence Committee (TIC)
  - 54 individuals / 26 companies

FINANCIAL SERVICES ISAC

Information Sharing: Traffic Light Protocol



Ensuring the Appropriate Audience

- Restricted to a defined group (e.g., only those present in a meeting.) Information labeled RED should not be shared with anyone outside of the group
- This information may be shared with FS-ISAC members.
- Information may be shared with FS-ISAC members and partners (e.g., vendors, MSSPs, customers). Information in this category is not to be shared in public forums
- This information may be shared freely and is subject to standard copyright rules

Members must have full control over whom information is shared with.

FINANCIAL SERVICES ISAC

FS-ISAC Operations

Information

GOVERNMENT SOURCES
- Security Services
- FS Regulators
- Law Enforcement
- Other Intel Agencies

PRIVATE SOURCES
- iSIGHT Partners
- Fox-IT
- Wapack Labs
- NC4 PhySec Incidents
- Secunia Vulnerabilities

FS-ISAC 24x7 Security Operations Center

CROSS SECTOR SOURCES
- Cross Sector (Other ISACs)
- Open Sources (Hundreds)

Member Communications
- Information Security
- Physical Security
- Business Continuity / Disaster Response
- Fraud Investigations
- Payments / Risk

Member Reports Incident to Cyber Intel list, or via anonymous submission through portal → **Members respond in real time with initial analysis and recommendations** → **SOC completes analysis, anonymizes the source, generates alert to members. Police liaison <u>when appropriate.</u>**

FINANCIAL SERVICES ISAC

Member Submissions
Alerts

FS-ISAC's Working Groups

Circles of Trust Govern Member Interaction

- Clearing House and Exchange Forum (CHEF)
- Payments Risk Council (PRC) (EU PRC in development)
- Payments Processor Information Sharing Council (PPISC)
- European Threat & Strategy Committee (ETSC)*
- APAC Threat & Strategy Committee (ATSC)
- Business Resilience Committee (BRC)
- Threat Intelligence Committee (TIC)
- European Threat & Strategy Committee (ETSC)
- Community Institution Council (CIC)
- Insider Threat Working Group (ITWG)

- Insurance Risk Council (IRC)
- Compliance and Audit Council (CAC)
- Cyber Intelligence Mailing Lists (Currently Intl., EU, APAC, ES)
- Education Committee
- Product and Services Review Committee
- Survey Review Committee
- Security Automation Working Group (SAWG)
- JWGI - European Regulatory & Legal Overview Working Group*
- JWGI - European Threat Intel Sharing Landscape Working Group*
- EU CAPP development group*

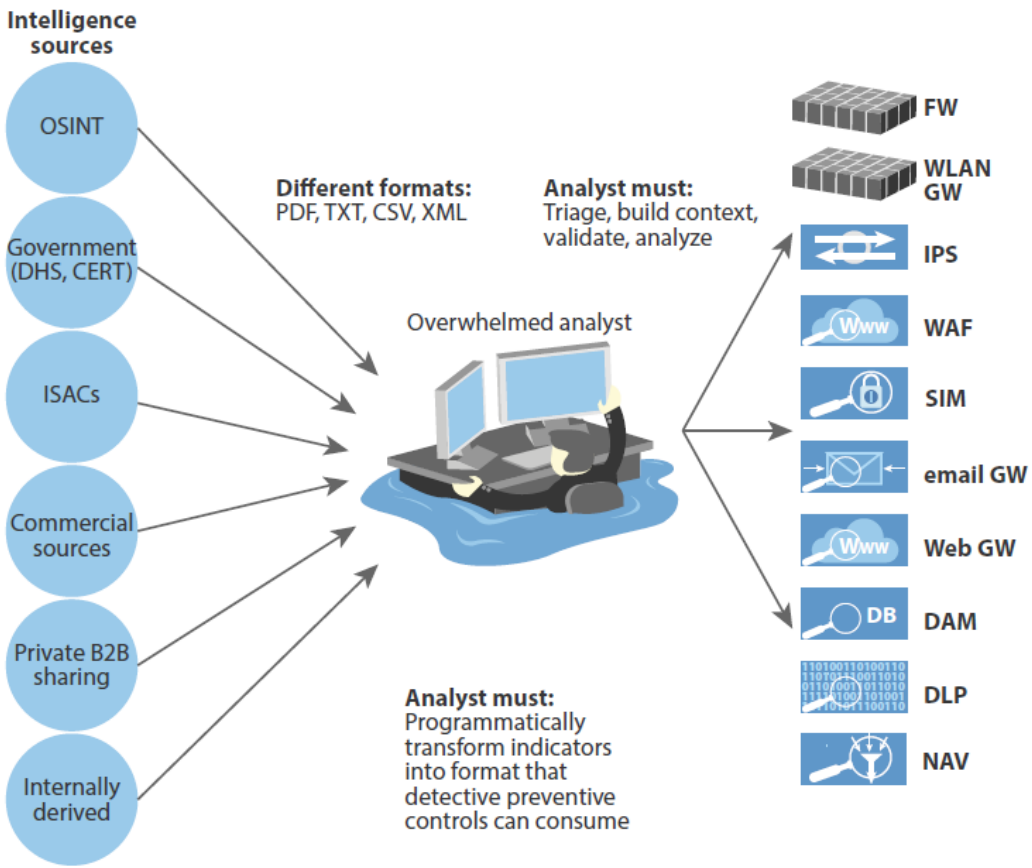
...Plus strategic cooperation with outside groups – banking federations, law enforcement, intel sharing schemes, CERTs, WGs, etc.

FINANCIAL SERVICES ISAC

Europe-specific groups. Other groups are inter-regional

Intelligence Data Overflow

Figure 2 Acting On Intelligence Overwhelms Analysts



98261

Source: Forrester Research, Inc.

FINANCIAL SERVICES ISAC

Threat Intelligence Standards

The Power of Structured Intelligence

- Key to effective strategic cyber intelligence analysis and threat tracking
- Ability to pivot, view, analyze, and enrich complex relationships
- Threat Language that Machines Speak ◎ STIX
  - Verbose
  - Structured
- Common Transport ◎ TAXII
  - Restful
  - Optimized for STIX
- Open standard supported by OASIS.

STIX

Structured Threat Intelligence eXpression

TAXII

Trusted Automated eXchange of Indicator Information

FINANCIAL SERVICES ISAC

www.oasis-open.org/committees/cti

STIX Constructs

An open standard to categorize cyber threat intelligence information

Atomic

What threat activity are we seeing?

Tactical

What threats should I look for on my networks and systems and why?

Operational

Where has this threat been seen?

What can I do about it?

What weaknesses does this threat exploit?

Strategic

Who is responsible for this threat?

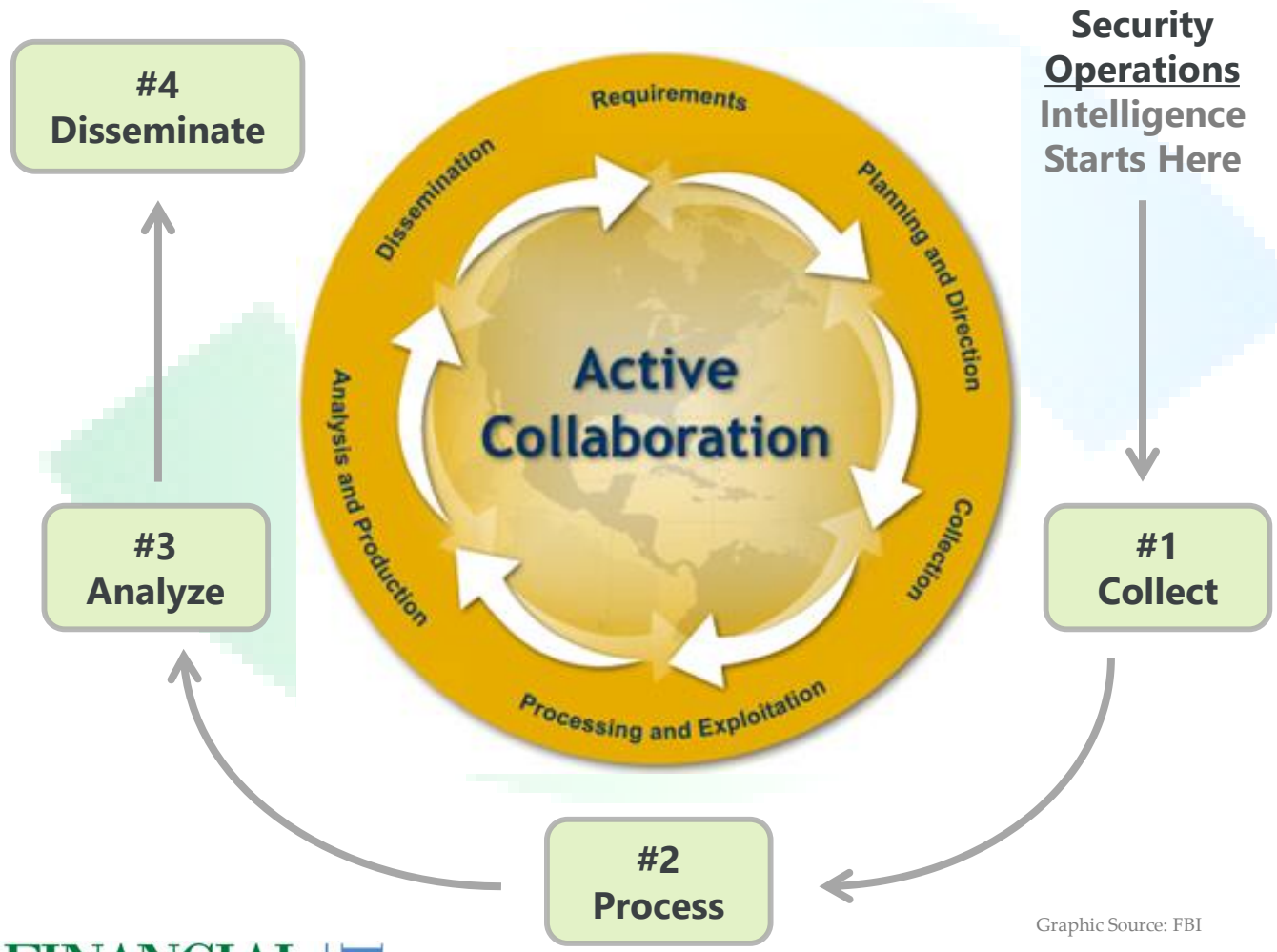
Why do they do this?

What do they do?

FINANCIAL SERVICES ISAC

The Intelligence Lifecycle

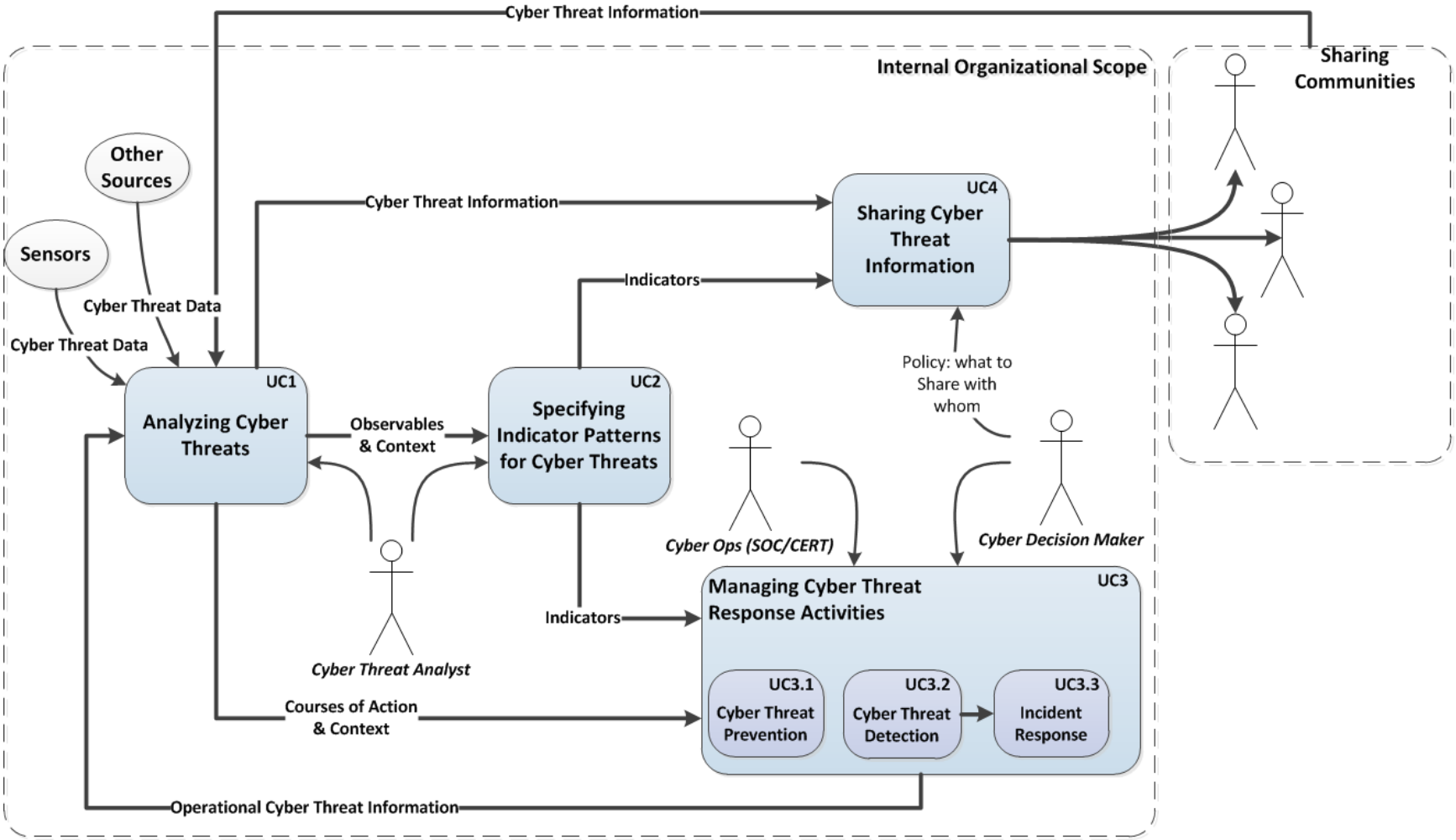
What Do We Do With It? **(What are we supposed to do with it?)**



Graphic Source: FBI

FINANCIAL SERVICES ISAC

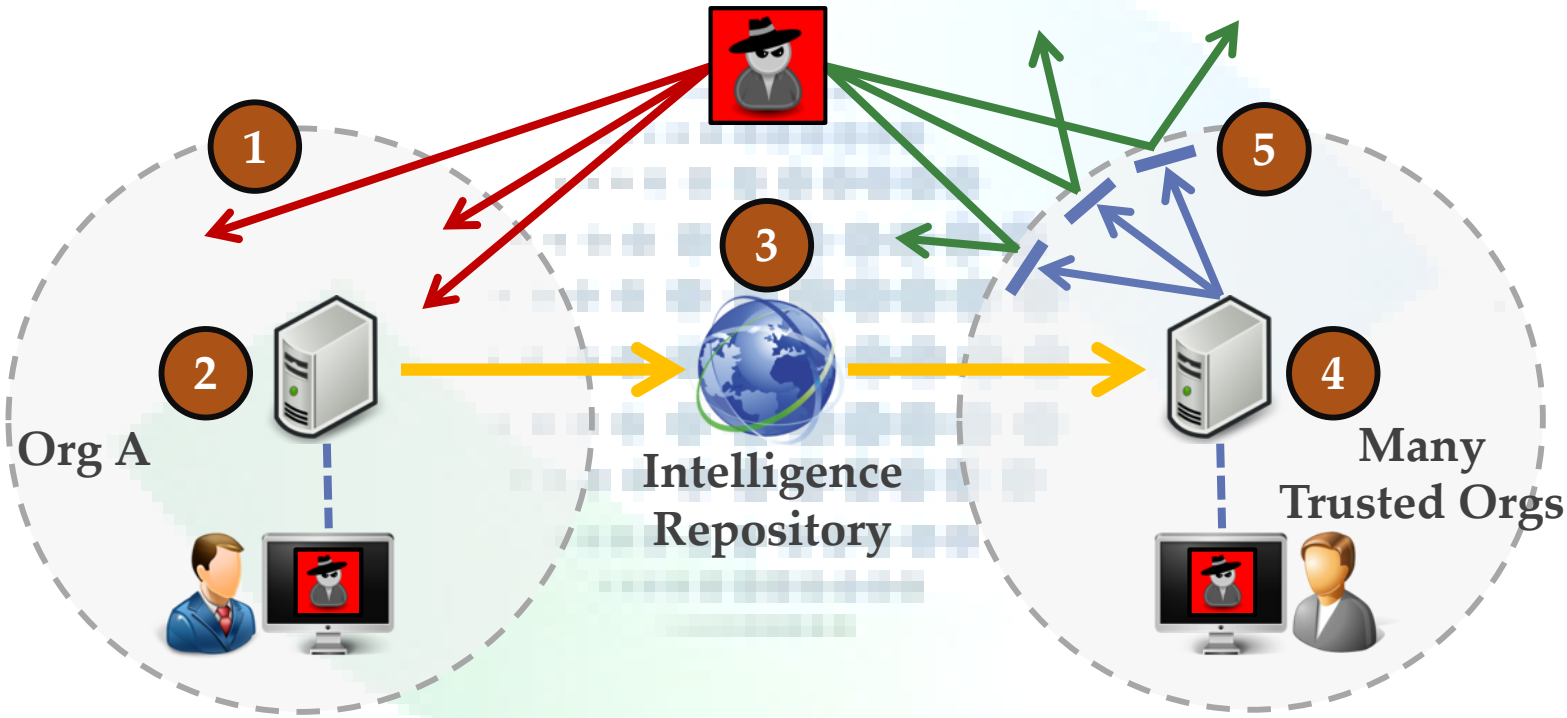
STIX Supported Use Cases



FINANCIAL SERVICES ISAC

Threat Intelligence Automation

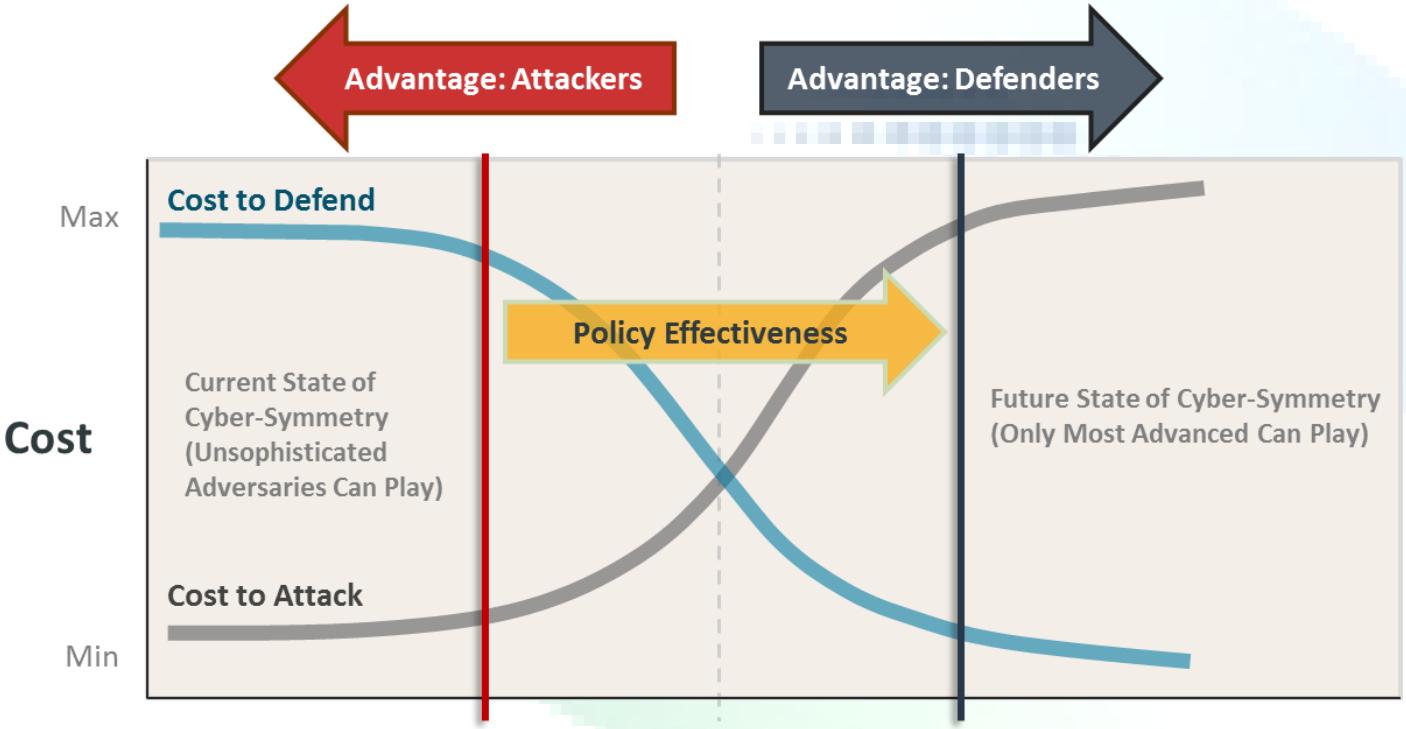
Instead of 2% or less of attacks blocked, detected, or prevented…



…a much higher percentage of attacks are stopped.

FINANCIAL SERVICES ISAC

Cyber Threat Economics 101



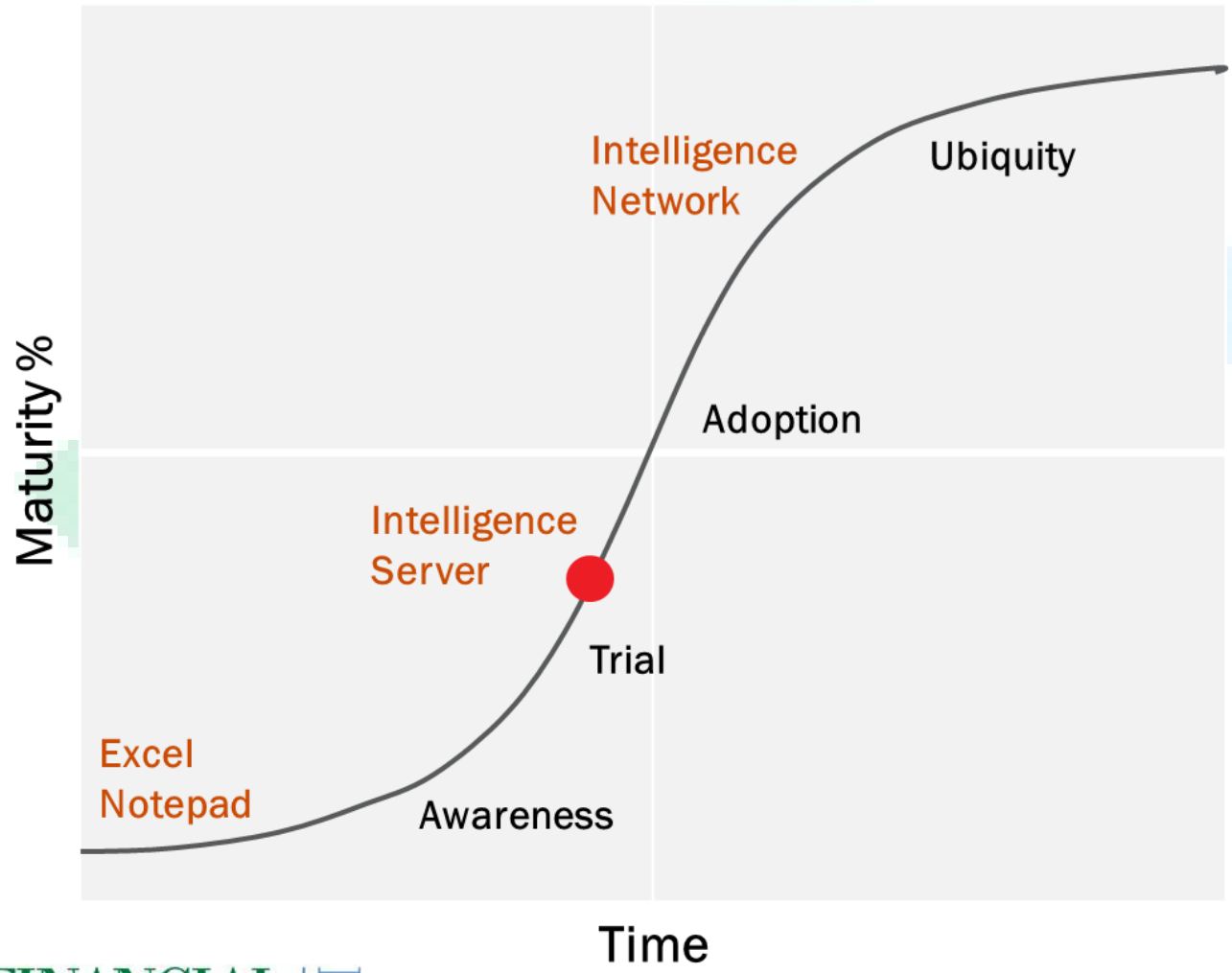
Cost to Firms ↓
The current cost to process a single piece of intelligence is 7 hours

Cost to Adversaries ↑
Adversaries must "re-tool" much more often and their exploits cause less damage

Cyber Risks ↓
Frequency and impact of threats decrease, higher adoption => exponential benefits

FINANCIAL SERVICES ISAC

Standards Adoption Today



FINANCIAL SERVICES ISAC

Soltra Edge

An FS-ISAC and DTCC Company

SOLTRA™

- Soltra is a joint venture between FS-ISAC and DTCC (Despository Trust and Clearing Corporation).
- Soltra Edge is a threat intelligence server that can aggregate and distribute threat content within an organization and between organizations
- Free to use, support available, download from www.soltra.com
- Soltra Net is coming in Q4 and will simplify connection of Soltra instances and include strong authentication.

FINANCIAL SERVICES ISAC

Your Next Steps With FS-ISAC…

Prospective Members: Try Our Services

- ✓ Try FS-ISAC for 6 months at no cost
- ✓ Access the threat indicators
- ✓ Get information from the FS-ISAC portal
- ✓ Participate fully in FS-ISAC events, summits, simulations…and help us shape them locally, regionally and globally to meet your needs
- ✓ Find out why 6,000 other institutions are members!

Existing Members: Leverage all that FS-ISAC Offers!

- ✓ Member portal: Educate more users on access to portal, threat indicators, playbooks, content, security automation
- ✓ Education: Executive briefing to update others on FS-ISAC
- ✓ Participation: Attend Summits, regional events, threat briefings, threat simulations and webinars

→ **If there is anything we can do to help, please let us know!**

"This year's threat simulation with FS-ISAC was a terrific exercise and very helpful for our executive management team in understanding the true, complex nature of today's threat environment…"

FINANCIAL SERVICES ISAC

Contact Details

Ray Irving
Director Continental Europe, Middle East and Africa
rirving@fsisac.eu
+41 76 303 50 70

FINANCIAL SERVICES ISAC

Thank You For Your Interest in FS-ISAC

Financial Services
Information Sharing & Analysis Center